Práctica. Enumeración de servicios web en TECNORIBERA

Nombre y apellidos: _____

Jueves 5 de noviembre de 2026 · HE · 4 horas · trabajo individual

En la práctica 4 sacasteis el inventario de TECNORIBERA: siete puertos, sus servicios y algunas rutas interesantes del portal. Hoy nos quedamos solo con lo que habla HTTP, que son tres servicios, y lo miramos más de cerca. La pregunta de hoy no es "qué puertos hay", sino qué aplicación hay detrás de cada puerto web, qué versión, qué cuenta de sí misma y qué hay de cierto en lo que dicen las herramientas.

Vais a usar cuatro herramientas que se solapan: nmap, WhatWeb, Nikto y OWASP ZAP. Las cuatro os van a dar resultados, y algunos serán exagerados, otros incompletos y alguno directamente falso. El trabajo de verdad, y lo que voy a evaluar, es que separéis lo **confirmado** de lo que es solo una **sospecha**, con una comprobación hecha a mano detrás de cada afirmación.

1. Qué vas a aprender hoy

1. Identificar el software y la versión de un servicio web contrastando varias fuentes.
2. Leer las cabeceras HTTP de una respuesta e interpretar las de seguridad.
3. Usar Nikto con límites de tiempo y guardar su salida.
4. Usar OWASP ZAP de forma pasiva: explorar y dejar que analice el tráfico, sin atacar.
5. Verificar a mano lo que dice una herramienta antes de darlo por bueno.
6. Documentar hallazgos con estado (confirmado, sospecha, descartado o no evaluado) y evidencia.

2. Alcance de hoy

Antes de teclear nada, apunta en la plantilla tu número de alumno, la IP de tu Kali, la fecha, la hora y quién te ha dado la autorización para empezar.

Dentro del alcance: la IP del portal que escribo en la pizarra al empezar la clase (en esta hoja la llamamos IP_PORTAL), puertos TCP **80, 8080 y 3000**, peticiones de lectura (GET, HEAD, OPTIONS) y las herramientas de esta hoja con las opciones que aparecen en ella.

Fuera del alcance: cualquier otra IP, red o puerto; los equipos de tus compañeros, el hipervisor, el SOC, la red del centro e Internet; iniciar sesión o probar contraseñas en ningún formulario (tampoco las "por defecto"); el escaneo activo de ZAP; cualquier prueba de explotación, fuerza bruta o envío de datos a formularios.

Las mismas normas de la práctica 4 siguen vigentes: un único proceso de escaneo a la vez, lo paras cuando yo lo diga o si ves errores en cadena, y nada de resultados copiados. Una herramienta que falla no da "cero hallazgos": da **no evaluado**.

3. Prepárate (20 minutos)

El portal de TECNORIBERA coge su IP por DHCP y cambia de una clase a otra, así que no uses la de la práctica 4. Copia la de la pizarra y guárdala en una variable de la terminal; todos los comandos de esta hoja la usan:

```
IP_PORTAL=172.20.10.5     # pon aquí la IP de la pizarra
echo $IP_PORTAL
```

Arranca tu Kali y comprueba que estás en la red del laboratorio y que llegas al objetivo solo por los puertos de hoy:

```
ip -br a
nc -zv -w 3 $IP_PORTAL 80
nc -zv -w 3 $IP_PORTAL 8080
nc -zv -w 3 $IP_PORTAL 3000
```

La primera orden muestra tus interfaces: tu Kali tiene que tener una IP de la misma red que el portal (los tres primeros números iguales que los de IP_PORTAL). Las otras tres intentan abrir una conexión TCP a cada puerto y la cierran. Tiene que salir `succeeded` u `open` en las tres. Si alguna falla, avísame antes de seguir: no cambies la red ni las rutas de la VM.

Comprueba que tienes las herramientas:

```
nmap --version | head -1
whatweb --version
nikto -Version
which zaproxy
```

Prepara tu carpeta de trabajo:

```
mkdir -p ~/he-web/salidas
cd ~/he-web
```

Copia dentro `plantilla-enumeracion-web.md`. Está en la web del curso (HE, Prácticas) y te la paso a la Kali igual que el material de la práctica 4, porque la red del laboratorio no tiene Internet. Si no la tienes, pídemela; mientras tanto puedes empezar la bitácora en un fichero de texto.

Todo lo que ejecutes hoy, apúntalo en la bitácora de la plantilla con la hora. Guarda las salidas en `salidas/`.

4. Primera pasada: qué hay detrás de cada puerto (40 minutos)

4.1. nmap con detección de versiones y scripts de lectura

```
nmap -sV -Pn -p 80,8080,3000 \
  --script http-title,http-headers,http-server-header,http-methods \
  -oN salidas/nmap-web.txt $IP_PORTAL
```

`-sV` intenta averiguar el software y la versión de cada puerto. `-Pn` se salta el ping previo (ya sabemos que el equipo está vivo). Los cuatro scripts que pasamos con `--script` hacen peticiones de consulta, sin intentar explotar nada: el título de la página, las cabeceras, la cabecera `Server` y los métodos HTTP que el servidor dice aceptar. Los cuatro son de las categorías `safe` y `discovery`; puedes comprobarlo tú con `nmap --script-help http-title`. `-oN` guarda la salida en un fichero de texto.

Rellena la columna "Software (nmap)" del inventario. Fíjate bien en lo que pone en la columna `VERSION` y en el `SERVICE` de cada puerto. Si en alguno aparece un servicio con un signo de interrogación al final, nmap te está diciendo que **no lo sabe** y que ha puesto el nombre que suele usar ese número de puerto. Eso no es un resultado: es una suposición.

4.2. WhatWeb

```
whatweb -a 1 --color=never http://$IP_PORTAL/ http://$IP_PORTAL:8080/ \
  http://$IP_PORTAL:3000/ | tee salidas/whatweb.txt
```

`-a 1` es el nivel de agresividad más bajo: una sola petición por URL, como haría un navegador. `tee` muestra la salida en pantalla y la guarda a la vez. WhatWeb reconoce tecnologías por lo que encuentra en la respuesta: cabeceras, cookies, títulos, scripts. Con la configuración por defecto, si una URL redirige a otra, WhatWeb sigue la redirección y te muestra una línea para cada una.

Completa la columna "Software (whatweb)". Mira en especial qué cookies aparecen, a qué página redirige alguno de los servicios y qué bibliotecas de JavaScript detecta.

4.3. Las cabeceras, a mano

```
curl -sI http://$IP_PORTAL/ | tee salidas/cabeceras-80.txt
curl -sI http://$IP_PORTAL:8080/ | tee salidas/cabeceras-8080.txt
curl -sI http://$IP_PORTAL:3000/ | tee salidas/cabeceras-3000.txt
```

`-I` pide solo las cabeceras (petición HEAD) y `-s` quita la barra de progreso. Esta es tu fuente de referencia: lo que ves aquí es exactamente lo que ha respondido el servidor, sin interpretación. Ten en cuenta que es la respuesta a una petición HEAD; si sospechas que una página responde distinto a un GET normal, compáralo con `curl -s -D - -o /dev/null URL`, que hace un GET y te enseña solo las cabeceras.

Rellena la tabla de cabeceras de seguridad. Para cada una, apunta si está, qué valor tiene y si tiene sentido aquí. Ojo con `Strict-Transport-Security`: obliga al navegador a usar HTTPS, pero solo la tiene en cuenta si la recibe por HTTPS. En un servicio que solo habla HTTP plano, su ausencia no es un hallazgo. El problema, si acaso, es que no haya HTTPS.

Al terminar este apartado, tienes que poder escribir en una frase qué aplicación hay en cada puerto. Si nmap, WhatWeb y las cabeceras no coinciden en algo, apúntalo en la columna "¿Coinciden?" y explica cuál te parece más fiable y por qué.

5. Nikto: muchas comprobaciones, muchas dudas (50 minutos)

Nikto lanza miles de peticiones buscando ficheros, configuraciones y versiones conocidas. Es ruidoso y genera muchos avisos, así que lo usamos con un tiempo máximo y de uno en uno:

```
nikto -h http://$IP_PORTAL/ -maxtime 300s \
  -o salidas/nikto-80.txt -Format txt
```

`-h` es el objetivo, `-maxtime 300s` corta el análisis a los cinco minutos aunque no haya terminado y `-o` con `-Format txt` guarda el informe en texto. Cuando termine, repite con el puerto 8080 y después con el 3000, cambiando la URL y el nombre del fichero. **No lances los tres a la vez.**

Al principio verás un error parecido a `Failed to check for updates`. Es normal: la red del laboratorio no tiene Internet y Nikto no puede comprobar si hay versiones nuevas de su base de datos. No afecta al análisis. Al final, la línea con `requests: 0 errors` te dice si ha podido trabajar bien; si ves muchos errores, el resultado de ese puerto es no evaluado.

5.1. Verifica cada aviso

Nikto escribe cada aviso con un `+` delante. Para cada aviso del puerto 80, decide su estado y apunta qué has hecho para decidirlo. Algunas comprobaciones que te van a servir:

```
curl -s -o /dev/null -w "%{http_code} %{content_type}\n" \
  http://$IP_PORTAL/RUTA
```

Esta orden pide la ruta y, en vez del contenido, te enseña el código HTTP y el tipo de contenido que ha devuelto el servidor. Cambia `RUTA` por la que indique Nikto.

```
curl -s http://$IP_PORTAL/RUTA | head -20
```

Esta te enseña las primeras veinte líneas del contenido. **Solo lectura**: no descargues ficheros enteros salvo los que ya analizasteis en la práctica 4, y no uses nunca los datos que encuentres para entrar en ningún servicio.

Hay tres tipos de aviso que tienes que aprender a distinguir:

1. **Lo que Nikto ha visto de verdad**: un fichero que existe y responde 200. Si compruebas el código, el tipo y el contenido y coinciden con lo que dice, está confirmado.

2. **Lo que Nikto deduce**: que una versión "está anticuada" o que hay una tecnología instalada. La deducción puede ser cierta o no. Para confirmarla necesitas otra prueba distinta del mismo dato. Por ejemplo, si Nikto dice que el servidor ejecuta un lenguaje, piensa qué cabecera o qué tipo de contenido esperarías ver si fuera cierto y compruébalo.
3. **Lo que Nikto recomienda**: las cabeceras "sugeridas". No son vulnerabilidades por sí mismas; son ausencias de medidas de defensa. Se apuntan, pero con su contexto.

Hay al menos un aviso en el puerto 80 que, cuando lo compruebes, vas a ver que no es lo que parece. Encuéntralo y explica en la plantilla por qué lo descartas o lo dejas como sospecha.

6. OWASP ZAP en modo pasivo (45 minutos)

ZAP es un proxy: se pone entre tu navegador y la web, ve todo el tráfico y lo analiza. Tiene dos tipos de análisis: el **pasivo**, que solo mira las respuestas que pasan por él, y el **activo**, que envía peticiones modificadas para provocar errores. Hoy **solo usamos el pasivo**. El escaneo activo está fuera del alcance.

1. Abre ZAP con `zaproxy &`. La primera vez te pregunta si quieres guardar la sesión: elige no guardar.
2. En el menú, Edit, ZAP Mode, elige **Safe**. En este modo ZAP no permite ninguna operación potencialmente peligrosa: ni escaneo activo ni araña. Solo verá lo que tú visites.
3. En la pestaña Quick Start, elige **Manual Explore** (no Automated Scan, que incluye ataque). Escribe `http://` seguido de la IP del portal y `/` (por ejemplo `http://172.20.10.5/`) y lanza el navegador.
4. Navega por el portal como un usuario normal: la portada y los enlaces que veas. No rellenes ni envíes formularios.
5. Repite los pasos 3 y 4 con los puertos `:8080/` y `:3000/` de la misma IP.

No uses la araña (Spider) aunque la veas en el menú: además de seguir enlaces, rellena y envía formularios por su cuenta, y eso está fuera del alcance de hoy. En modo Safe, ZAP no te dejará lanzarla.

Ahora abre la pestaña **Alerts**. Ahí están los avisos del análisis pasivo, agrupados por tipo y con un nivel de riesgo. Exporta el informe desde el menú Report, Generate Report, en formato HTML, y guárdalo en `salidas/zap-informe.html`. Comprueba que en el informe solo aparecen sitios de IP_PORTAL.

Como solo analizas lo que visitas, ZAP verá menos rutas que Nikto. No es un fallo: es la diferencia entre mirar el tráfico y buscar rutas. Apúntalo en las limitaciones.

7. Contrasta y documenta (30 minutos)

Rellena la tabla de comparativa de herramientas: para cada hallazgo, qué herramientas lo han detectado y cuáles no. Seguramente verás que ninguna lo ve todo. Piensa en por qué. Una pista: no todas las herramientas piden las mismas rutas.

Después completa la tabla de hallazgos. Cada uno con:

- Un identificador (`W-01`, `W-02`...).
- Puerto y ruta.
- Lo que dice la herramienta, con sus palabras.
- Lo que has comprobado tú, con el comando.
- El estado: **confirmado**, **sospecha**, **descartado** o **no evaluado**.
- El fichero de `salidas/` donde está la evidencia.

No hace falta valorar todavía el riesgo de cada hallazgo: eso lo haremos la semana que viene. Hoy importa que lo que escribes sea cierto y se pueda comprobar.

8. Si algo no funciona

`nc` dice `Connection refused` o `timed out`: el servicio puede estar parado en el servidor del laboratorio o tu VM no está en la red correcta. Comprueba con `ip -br a` que tu IP es de la misma red que IP_PORTAL y con `echo $IP_PORTAL` que la variable tiene la IP de hoy, y avísame. No intentes arreglarlo tocando la red.

nmap dice `No targets were specified`, `curl -sI` no saca nada o whatweb se queja de la URL: casi seguro que has abierto otra terminal y la variable se ha perdido. Compruébalo con `echo $IP_PORTAL`; si sale vacío, vuelve a escribir `IP_PORTAL=` con la IP de la pizarra.

nmap tarda muchísimo: comprueba que has puesto `-p 80,8080,3000`. Sin esa opción escanea mil puertos.

WhatWeb no muestra nada o da error de conexión: prueba la misma URL con `curl -sI`. Si `curl` tampoco llega, el problema es de red, no de WhatWeb.

Nikto se para con `ERROR: Unable to connect`: revisa que la URL lleve `http://` y el puerto correcto. Si sale `+ 0 host(s) tested`, el análisis no ha hecho nada: apúntalo como no evaluado.

ZAP no abre el navegador: en Quick Start, Manual Explore, prueba a cambiar de Firefox a Chrome o al revés. Si no hay ninguno, puedes configurar el proxy de Firefox a mano en `127.0.0.1` puerto `8080` de tu Kali. Ojo: ese 8080 es el de ZAP en tu Kali, no el del objetivo.

ZAP va muy lento o se cierra: necesita memoria. Cierra otras aplicaciones de la VM y vuelve a abrirlo.

9. Elige tu itinerario (35 minutos)

Haz uno de los dos, no los dos.

Recuperación

Si tienes la práctica 4 pendiente, termina antes el inventario activo (HE-E10) con su bitácora, siguiendo la guía paso a paso de la práctica 4 que tienes en la web. Después haz de esta hoja, como mínimo, los apartados 4 y 5 solo para el puerto 80.

Ampliación

1. Compara la versión de nginx que anuncia el portal con las versiones publicadas en `nginx.org`. Busca en la base de datos de vulnerabilidades de nginx (está en la propia web de nginx) cuáles afectan a esa versión. No las pruebes: explica qué condiciones tendrían que darse para que alguna fuera aplicable a este servidor y qué te falta saber para confirmarlo.
2. Repite el análisis de cabeceras del apartado 4.3 sobre la página de inicio de sesión del puerto 8080 y explica qué atributos tienen (o no tienen) las cookies que se establecen (`HttpOnly`, `Secure`, `SameSite`) y qué riesgo supone cada ausencia. Solo lectura: no inicies sesión.

10. Preguntas

1. ¿En qué puerto no ha sabido nmap identificar el servicio y cómo lo has averiguado tú?
2. ¿Qué aviso de Nikto has descartado o dejado como sospecha y qué comprobación te ha llevado a esa conclusión?
3. ¿Por qué ZAP pasivo no detecta algunas rutas que Nikto sí ha encontrado?

4. ¿Qué diferencia hay entre que falte una cabecera de seguridad y que exista una vulnerabilidad?
5. Si un cliente te pidiera solo una herramienta para esta fase, ¿cuál elegirías y qué te perderías?

11. Qué tienes que entregar (20 minutos)

Carpeta `NN-HE-enumeracion-web` en ZIP con:

1. `plantilla-enumeracion-web.md` completa: bitácora, inventario, cabeceras, hallazgos, comparativa y limitaciones.
2. La carpeta `salidas/` con todos los ficheros generados (nmap, WhatWeb, cabeceras, Nikto de cada puerto e informe de ZAP).
3. Las respuestas a las preguntas del apartado 10.

Si alguna herramienta no ha funcionado, en vez del fichero entrega la explicación de qué ha pasado y qué has comprobado. Eso cuenta.

12. Antes de entregar, comprueba que

1. Todas las órdenes de la bitácora apuntan a IP_PORTAL (apunta la IP de hoy en la cabecera de la plantilla) y a los puertos 80, 8080 o 3000.
2. Cada hallazgo tiene estado y una comprobación tuya, no solo lo que dice la herramienta.
3. Los resultados vacíos o con error están marcados como no evaluados.
4. No hay contraseñas ni contenido de ficheros sensibles copiado en la entrega: basta con la ruta y el código HTTP.
5. Has cerrado ZAP y no queda ningún escaneo en marcha (`ps aux | grep -E "nikto|nmap"` no debe mostrar nada más que la propia búsqueda).

13. Seguridad y ética

Todo lo de hoy se hace contra un laboratorio aislado y autorizado. Las mismas órdenes contra un servidor sin permiso por escrito de su responsable son ilegales, aunque "solo mires". En una auditoría real, el alcance se firma antes de empezar y se respeta al pie de la letra, también cuando una herramienta te tienta a ir un poco más allá.

Los datos que encontréis en el portal (ficheros de configuración, copias de seguridad) son ficticios y forman parte del ejercicio. Aun así, tratadlos como si fueran reales: se citan en el informe, no se copian ni se usan.

Referencias

- Guía de nmap, detección de versiones: https://nmap.org/book/vscan.html
- Scripts NSE y sus categorías: https://nmap.org/book/nse-usage.html
- Nikto: https://github.com/sullo/nikto/wiki
- OWASP ZAP, modos y análisis pasivo: https://www.zaproxy.org/docs/desktop/start/features/modes/
- OWASP Web Security Testing Guide, fase de recogida de información: https://owasp.org/www-project-web-security-testing-guide/
- Cabeceras de seguridad (MDN): https://developer.mozilla.org/es/docs/Web/HTTP/Headers